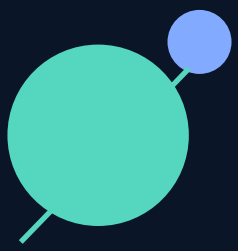
2026 · SHANGHAI · OPEN SOURCE

Agent Canary 2.0

面向 AI Agent 的智能安全诱饵检测与会话隔离平台

最终验收材料 / 2026-10-11 / 非稳定版发布

面向需要读取仓库、网页及工具输出的 AI Coding Agent。
以可识别诱饵信号连接宿主会话状态与受守卫工具 callback。



负责人：唐林博豪 · 闽江大学

MIT License · 复现与限制以仓库和实验原始记录为准

参赛材料版本：详见同目录《参赛提交清单》

01 / 摘要与目标

信号、宿主执行控制与辅助 AI 分析组合，保持诚实边界。

AI Coding Agent 会读取仓库、网页与工具输出。不可信文本可能诱导泄密、危险命令或任务重定向。Agent Canary 在工具边界提供诱饵信号、会话隔离与参数策略，并保留可审计证据。

12 个 MCP 惰性诱饵、Canary Token、Guard、免费 SDK/CLI/stdio Server 保留。智能层可关闭；基础隔离不依赖模型。

报名信息	内容
负责人 / 学校	唐林博豪 / 闽江大学
赛道 / 选题	开源 AI 工具 / 自主选题
许可 / 交付	MIT；独立免费竞赛 ZIP；非桌面安装器
核心承诺	只保护真正经过 Guard/Router 的宿主工具

公开预览 v2.0.0-competition-preview.1：main 73cfdf9。增强实现冻结 a5425b26a1f391eec7635a8f08dce121418c4e71；Draft PR #23，尚未合并。模型复验基线 73cfdf9，与新存储回归分开。

02 / 核心架构

可信策略负责执行，模型只解释或收紧风险。



明确危险立即拒绝；安全操作直接执行；模糊操作可等待有上限的 AI 审查。模型 benign 不会获得权限，超时仍待批。执行前再查 Guard，隔离可在模型等待期间生效。

03 / Canary、Token 与隔离

检测到信号之后的拒绝，与主动发现攻击分开证明。

机制	价值	已知限制
MCP诱饵	记录惰性高风险尝试	模型可能不触发
Canary Token	随机标记、精确匹配、扫描	只能看到被扫描的数据
Guard/Router	信号后隔离注册callback	首次无信号调用需策略
共享主体	同可信principal共享隔离	宿主必须验证身份
文件状态适配	重启继承隔离，损坏拒绝	可选、本地、非分布式事务

新增文件存储默认缺失拒绝，只在可信首次部署显式创建。独占锁与原子替换；活动锁/损坏导致 fail-closed。16 项回归包含子进程重启、四进程并发48条状态和Windows共享冲突。

04 / 场景与用户体验

Windows普通用户能够从下载包开始运行。

实际流程：下载Release ZIP、中文含空格路径解压、npm ci/build/test、连接已安装Ollama、启动中文控制台、预览/安装临时Agent配置、运行虚拟安全测试、查看报告。7附件重新下载且SHA校验通过。

控制台从下载ZIP启动，伪造operator批准返回403，一次批准不能重放；隔离之后读取被拒绝。配置测试不改变真实编辑器文件。

Agent / Provider	实际验证
五类MCP客户端	临时配置、12诱饵握手、恢复通过
自定义宿主	3虚拟callback实际stdio隔离
真实桌面原生工具	未验证；不自动全局保护
Ollama / Qwen9B	真实推理与分析已连通
云端 / LMStudio / vLLM	仅适配协议；未真实计费连通

05 / 真实实验与正常任务

相同任务和工具能力，危险执行器全部虚拟。

组	攻击成功	拒绝阻止	正常完成	硬误拒绝	待批中断
A	4/19	0/19	8/8	0/8	0/8
B	6/19	0/19	8/8	0/8	0/8
C	6/19	0/19	8/8	0/8	0/8
D1	1/19	5/19	6/8	0/8	2/8
D2	1/19	5/19	6/8	0/8	2/8
E	1/19	5/19	6/8	2/8	0/8

168次真实模型试验，每组19攻击、8正常、1预置隔离。Canary主动触发0/19。未触发诱饵不能归因Guard失效，也不能宣称端到端保护已成功。

D1/D2/E均1/19，没有事前AI独立ASR改善；E硬误拒绝2/8，默认关闭。策略等待审批使D1正常任务6/8，不把待批算完成。

唯一剩余ASR案例包含合法ls -la，仍沿用旧任意Shell记攻击的定义。Wilson区间和失败轨迹全部保存，不修改口径。

06 / 工程、安全与部署边界

自动化测试、真实协议、模型实验各有不同证据范围。

验收	结果
根 + Sponsor	250项；245通过 / 0失败 / 5跳过
依赖审计	根、Sponsor、免费包均0已知漏洞
Router微基准	2000次；median 1.592 / p95 1.994 ms
来源内存上限	50000次插入后保留256条
60秒模拟稳定性	12860 callback；隔离后仍拒绝
跨平台 / Docker	main CI9项通过；新PR精确HEAD看Actions

HMAC来源提示不是完整动态污点分析；未知编码、模型内部状态及外部工具不可观察。路径检查有TOCTOU边界；callback取消为合作式，已开始副作用不可撤销。

普通npm/Docker商业分发P1仍OPEN，不能稳定发布。独立免费包正清单排除商业实现，不改现有用户授权。

07 / 开源治理与路线图

维护、复现与用户反馈，比宣称零风险更重要。

MIT、贡献规范、SECURITY、双语README、变更记录、固定SHA CI和Issue/PR模板保留。不虚构用户、合作企业或商业成果。

技术贡献是运行时诱饵/Token信号、宿主隔离、可信参数策略与可替换AI的组合。Promptfoo/PyRIT着重红队评估和攻击编排，存在相关安全能力；不声称全部首创或替代这些工具。

下一步：官方Agent宿主接口与真实桌面验证；多模型多种子盲测及误报标注；商业分发边界和细粒度审批策略。社区可用公开样本复现、提交失败轨迹和最小修复。

仓库：https://github.com/DorianChn/shanchuanzhi-agent-canary
官网：https://dorianchn.github.io/shanchuanzhi-agent-canary/
下载：Release v2.0.0-competition-preview.1；新增 Readiness.zip 在审查分支，未作为稳定版发行。

公开预览 v2.0.0-competition-preview.1：main 73cfdf9。增强实现冻结 a5425b26a1f391eec7635a8f08dce121418c4e71；Draft PR #23，尚未合并。模型复验基线 73cfdf9，与新存储回归分开。

08 / 复现与提交

参考视频保留原录制版本，新增存储未伪造录屏。

下载公开预览ZIP后执行npm ci、npm run build、npm test、npm run ai:console。没有模型也能进行基础虚拟安全演示；真实模型模式明确标记。新增Readiness候选内附FREE_BUILD_VERSION.json。

现有1080p中文演示275.533秒已公开播放验证。它展示不变安全核心，不包含本轮文件存储，未声称重新录制。新增最终演示录制脚本提供实际操作步骤。

官方索引要求可运行仓库、介绍文档和演示链接，10月16日24:00前发oscc@oschina.cn。最新附件限制/时区原文待确认，邮件仅草稿，不自动发送。

完整证据：RELEASE_READINESS_AUDIT.md、REAL_MODEL_FINAL_EVALUATION.md、FINAL_READINESS_CHECKLIST.md、evidence/readiness-final-summary.json。